

ISO/IEC 27001:2022 Annex A controls table

Classification	Control ID	Control Name	Possible Implementation	Control Owner	Applicability	Evidence
			1. Write a different policies that states what data is protected and why. 2. Require executive approval before the policy is active. 3. Review and update the policy after major incidents or product changes. 4. Ensure each department that each information policy applies to is well informed of any change in the policy via official channels. 5. Ensure all created policy remain confidential and write access is not given to anyone outside of the information security department.			
	A.5.1	Policies for information security		Security Lead	Applicable	Policy documents
			Name a person responsible for overall security. Assign owners for access, incidents, vendors, and systems. Define who can approve risky decisions. Document escalation paths. Review responsibilities annually.	Executive Management	Applicable	Governance records
	A.5.2	Information security roles and responsibilities				
			Prevent one person from approving and executing sensitive actions. Split refunds, payouts, and system changes across roles. Enforce separation in systems, not just on paper, especially in loan applications, with a different personnel verifying each loan guarantors before the loan is disbursed. Review roles and remove conflicting permissions immediately.	Security Lead	Applicable	Role definitions
	A.5.3	Segregation of duties				
			Require managers to enforce security rules in their teams Record management approval for accepted risks Block work that violates security rules Include security in management reviews Hold managers accountable for repeated violations	Executive Management	Applicable	Management attestations
	A.5.4	Management responsibilities				
			Maintain a list of regulators and law enforcement contacts Define who is allowed to make contact Store contact details securely and review contacts annually Practice contact procedures during simulations	Legal / Compliance	Applicable	Regulatory contacts
	A.5.5	Contact with authorities				
			Identifying relevant groups documenting interactions, and using this information to enhance the ISMS	Security Lead	Applicable	Industry memberships
	A.5.6	Contact with special interest groups				
			Monitor fraud and attack trends in similar companies. Review intelligence weekly or monthly. Assess relevance to company systems. Update controls when threats change. Document decisions.	Security Lead	Applicable	Threat intelligence reports
	A.5.7	Threat intelligence				
			Security requirements must be embedded in existing project management methodologies. Information security risks to projects and deliverables must be identified and managed throughout the project lifecycle. Security should be considered at the earliest stages to avoid costly rework and vulnerabilities. Evidence of security requirements, risk assessments, and control implementations must be maintained.	PMO	Applicable	Project security templates
	A.5.8	Information security in project management				
			Categorize assets into Information (data, databases), Physical (servers, laptops), Software (applications, SaaS), and Services. Define a specific owner (person or role) for every asset to handle classification, usage, and disposal. Document assets in a central register, including name, type, location, owner, and classification, and regularly update the inventory during employee leaving or onboarding, or if new assets is bought by the organization or decommissioned.	IT Manager	Applicable	Asset register
	A.5.9	Inventory of information and other associated assets				

	A.5.10	Acceptable use of information and other associated assets	Define rules and communicate prohibited actions clearly to staff. Create a formal Acceptable Use Policy (AUP) defining rules for email, internet, BYOD, and data handling. Train employees, contractors, and third-party users on the rules during onboarding and periodically. Ensure EDR is automatically programmed with rules to block unacceptable behaviour. Implement monitoring tools to detect violations and apply disciplinary measures for non-adherence.	HR / IT	Applicable	Acceptable use policy
	A.5.11	Return of assets	Create an asset inventory linking every device (laptops, phones, tokens) and software license to specific users. Ensure return of assets is included in all employee contracts to ensure legal obligation. Integrate a, check-list, or automated workflow into the HR departure and supplier offboarding process to ensure all assets are accounted for during termination, and keep records of assets upon return. Treat failure to return assets as a security incident, initiating formal follow-up actions.	HR / IT	Applicable	Exit checklist
	A.5.12	Classification of information	Create an Information Classification and Handling Policy defining classification levels (e.g., Public, Internal, Confidential, Restricted) and criteria for each. Set specific rules for storing, sharing, and destroying data based on its classification (e.g., encryption for confidential data). Train staff on handling and review classification annually.	Security Lead	Applicable	Classification scheme
	A.5.13	Labelling of information	Create a clear, documented policy defining how information is labeled throughout its lifecycle. Apply labels to all formats, including documents, emails, removable media, and physical devices. Train employees to understand and correctly apply labels. Keep an inventory of assets and their assigned labels, ensuring consistency across the organization.	Security Lead	Applicable	Data labels
	A.5.14	Information transfer	Define rules, procedures, and agreements for all forms of data transfer (electronic, physical, verbal). Use encryption, secure transfer protocols (SFTP, HTTPS), and Virtual Private Networks (VPNs) for electronic transfers. Block personal email for sensitive data.	IT Manager	Applicable	Transfer procedures
	A.5.15	Access control	Define roles based on job functions to ensure users only have the access required for their work. Ensure principle of less privilege across the organisation. Enforce strong passwords and Multi-Factor Authentication (MFA), especially for remote or privileged access. Promptly remove or update access when employees leave or change roles. Conduct periodic audits (at least annually) of access rights and user permissions. Ensure physical access to offices and server rooms is restricted, for example, via key cards or visitor logs	IT Manager	Applicable	Access control policy
	A.5.16	Identity management	Documented processes for the creation, maintenance, and deletion of user, service, and device identities. Each user must have a unique ID; shared accounts must be strictly restricted, justified, and documented. Before an identity is created, the user or entity must be verified, often linked to onboarding/screening processes. Specific, strict controls for administrative accounts, requiring extra security and monitoring. Centralize identity records and do periodic audit of all identities	IT Manager	Applicable	IAM procedures

Organizational

A.5.17	Authentication information	Develop procedures for the allocation, change, and revocation of authentication data (passwords, tokens, biometrics). Generate temporary, non-guessable passwords that require immediate change upon first use. Implement MFA for all remote access points, cloud services, and privileged accounts. Ensure passwords are encrypted (e.g., using Argon2 or bcrypt) at rest and never shared in plain text. Train staff regularly on how to keep password secure.	IT Manager	Applicable	MFA configurations
A.5.18	Access rights	Strictly manage, limit, and audit administrative accounts to prevent misuse. Ensure that those who authorize access are not the same individuals who implement it. Maintain logs of all access requests, approvals, and changes for auditor review. Ensure, monitor, and regularly review access provided to vendors and contractors.	IT Manager	Applicable	Access review logs
A.5.19	Information security in supplier relationships	Develop a comprehensive, up-to-date list of all suppliers, including contact info, services provided, and classification. Evaluate the risks associated with each supplier. For critical vendors, review their security controls, policies, and certifications. Include specific, enforceable information security clauses in all contracts. These should define data handling, incident reporting, confidentiality, and security requirements. Regularly review supplier compliance with security requirements, using audits or evidence of compliance (e.g., SOC 2 reports, ISO 27001 certificates). Monitor changes in the supplier environment.	Procurement	Applicable	Supplier risk assessments
A.5.20	Addressing information security within supplier agreements	Define necessary security controls based on the data access and criticality of the supplier. Include binding clauses for confidentiality, security incident reportin, and data handling. Include clauses allowing the organization to verify compliance, or request independent evidence like SOC 2 reports or ISO certificates. Define procedures for returning or destroying data upon contract termination and review contracts periodically.	Legal	Applicable	Contract templates
A.5.21	Managing information security in the ICT supply chain	Create procedures for assessing, evaluating, and treating risks associated with ICT suppliers. Identify, classify, and assess the criticality of ICT suppliers, focusing on data access, software development procedures, and security capabilities. Ensure agreements define security responsibilities, such as required security levels, incident notification, and audit rights. Regularly review supplier security posture, compliance with SLAs, and performance through audits or certifications. Verify that suppliers follow secure development, testing, and production segregation for products, and ensure secure data handling upon contract termination.	IT / Security	Applicable	Supply chain risk register
A.5.22	Monitoring, review and change management of supplier services	Define clear metrics and key performance indicators (KPIs) to track supplier adherence to security requirements, such as security incidents, uptime, and vulnerability management. Perform regular assessments based on supplier risk level to evaluate their security posture. Implement a formal procedure to review and approve any changes to supplier services to prevent new risks. Ensure supplier security incidents are documented, investigated, and remediated.	Procurement	Applicable	Supplier review records

	A.5.23	Information security for use of cloud services	Define formal procedures for selecting, acquiring, and managing cloud providers and a shared responsibility model. Enforce strong authentication, including Multi-Factor Authentication (MFA), for all cloud services and implement encryption for data at rest and in transit. Conduct regular audits of cloud service providers based on the risk level of the data. Continuously monitor cloud usage for security incidents and, unusual activity using logs and alerting systems and employees are well trained on possible risks.	IT / Security	Applicable	Cloud security baseline
	A.5.24	Information security incident management planning and preparation	Explicitly document in contracts which incident response tasks belong to the organization and which belong to the CSP. Create a tailored procedure detailing steps for detecting, containing, and eradicating threats within cloud environments. Utilize cloud-native tools to detect security events in real-time, focusing on unauthorized access and misconfigurations. Test the cloud incident response plan at least annually through simulations to verify team readiness and effectiveness of technical controls.	Security Lead	Applicable	Incident response plan
	A.5.25	Assessment and decision on information security events	Define clear channels for employees to report suspicious events and a standardized report template. Establish a framework for evaluating events, categorizing them based on confidentiality, integrity, and availability impact. Utilize automated tools (e.g., SIEM, IDS systems) to monitor systems, networks, and applications in real-time. Ensure incidence are reported immediately to the CISO.	Security Lead	Applicable	Event assessment records
	A.5.26	Response to information security incidents	Create an Incident Management Plan (IMP) that defines roles. Create a 3-tier severity matrix (Low, Medium, High) that aligns with your risk assessment to determine response priority. Implement automated segmentation or NAC (Network Access Control) to quarantine compromised devices instantly. If a breach is suspected to lead to legal or disciplinary action, evidence must be collected and preserved. Conduct a post-incident review (PIR) for every major incident to document what happened, why it happened, and how the response was managed.	Security Lead	Applicable	Incident reports
	A.5.27	Learning from information security incidents	Conduct post-incident reviews Identify root causes Update controls Track corrective actions Share lessons internally	Security Lead	Applicable	Lessons learned reports
	A.5.28	Collection of evidence	Establish a formal, documented procedure that outlines the entire lifecycle of evidence management to ensure compliance and integrity. Ensure that collected evidence is stored in a way that prevents tampering and proves its integrity. Manual evidence gathering is prone to errors and time-consuming; leveraging automation is recommended to ensure consistency and audit readiness e.g implement SIEM.	Security / Legal	Applicable	Evidence handling logs
	A.5.29	Information security during disruption	Maintain access controls during outages Prevent emergency bypass abuse Log emergency actions Restore normal controls promptly Review disruption handling	BCM Lead	Applicable	BCP procedures
	A.5.30	ICT readiness for business continuity	Execute a Business Impact Analysis (BIA) to identify critical ICT systems, applications, and their dependencies. Define RTO and RPO for each critical system.	IT Manager	Applicable	DR test results

A.5.31	Legal, statutory, regulatory and contractual requirements	Develop a centralized register (spreadsheet or software) documenting all relevant laws (e.g., GDPR, CCPA), regulations, and contractual requirements. Appoint specific owners and ensure owners are responsible for identifying new obligations and updating the register. Map the legal requirements to existing policies and procedures. Conduct periodic reviews and include compliance status in management reviews and audit findings.	Legal / Compliance	Applicable	Compliance register
A.5.32	Intellectual property rights	Create a centralized register detailing the owner, location, and sensitivity of each IP asset. Update employment and contractor agreements to explicitly state that all IP created during employment belongs to the organization. Include clear Non-Disclosure Agreement (NDA) clauses with third parties to define IP ownership and prevent unauthorized usage. Implement access controls and Role-Based Access Control (RBAC) to restrict access to sensitive IP to authorized personnel only. Conduct mandatory, regular awareness training to educate staff on what constitutes IP and their responsibilities in protecting it.	Legal	Applicable	IP protection policy
A.5.33	Protection of records	Conduct an audit to map all record types (financial, legal, HR, project data) and their locations (physical, cloud, local drives, shadow IT). Create an inventory listing every record and ensure every record have a designated owner. Create an inventory listing every record and set up alert for when a record reach end of life. Protect records from tampering. Develop a procedure for the permanent destruction of records when they are no longer needed.	Legal / IT	Applicable	Records retention schedule
A.5.34	Privacy and protection of PII	Conduct data discovery to identify all PII sources (employee records, customer databases, third-party data, CCTV). Collect only necessary PII and delete it when no longer needed, and ensure they are properly documented Use layered security to protect PII, like encryption, obfuscation, RBAC. Appoint a Data Protection Officer (DPO) or Privacy Lead. Develop a Privacy and Protection of PII Policy and train staff.	DPO / Legal	Applicable	Privacy controls
A.5.35	Independent review of information security	Schedule regular reviews using external auditors or independent internal personnel to ensure objectivity. Review all aspects of security, including personnel security, physical security, and technology. Document all identified gaps,, non-conformities, or weaknesses in a formal report and ensure top management assigns responsibility for implementing corrective actions. Monitor the implementation of recommended improvements to ensure risks are addressed	Internal Audit	Applicable	Audit reports
A.5.36	Compliance with policies, rules and standards for information security	Define explicitly permitted and prohibited behaviors and the full cycle of information including rules for secure storage, retention and disposal. Formally Communicate and Obtain User Acknowledgement that the controls have been read and understood, and include security training during onboarding. Implement Technical Enforcement Mechanism like WAF, EDR and ensure principle of least privileged is implemented. Use SIEM to ensure policies are being followed and ensure a well laid down disciplinary process for policy violation.	Security Lead	Applicable	Compliance monitoring logs

People	A.5.37	Documented operating procedures	Identify which, operational tasks require documentation based on risk, such as user provisioning, system backups, software updates, or incident response. Write procedures using standard tools (e.g., MS Word, Google Docs) and store them in a centralized, easily accessible location Do not just create documents; actively train staff on new procedures and communicate their importance to ensure adoption and adherence. Ensure continuous review of procedures to ensure it is always up to date.	IT / Security	Applicable	SOP documentation
	A.6.1	Screening	Create a document that defines the required background checks for different roles based on risk. Include identity verification, academic/professional credentials, and 3-5 years of employment history. Include identity verification, academic/professional credentials, and 3-5 years of employment history. Ensure all screening activities adhere to local data protection laws Store screening records securely with restricted access (only to authorized HR/Legal personnel)	HR	Applicable	Screening records
	A.6.2	Terms and conditions of employment	Work with HR and Legal to incorporate clauses requiring employees to adhere to the Information Security Policy (ISP), Acceptable Use Policy (AUP), and data protection regulations (NDPR). Include clauses on the ownership of intellectual property (IP) and data created during employment. Require all personnel to sign a Confidentiality or Non-Disclosure Agreement (NDA) prior to being granted access to sensitive information assets. Include a reference to the organization's disciplinary policy in the contract. Store all signed agreements or contracts in a secure, digital, and easily accessible repository and review contract templates regularly for legal compliance.	HR	Applicable	Employment contracts
	A.6.3	Information security awareness, education and training	Conduct a training needs analysis to identify high-risk roles and train staff according to their department. Train new employees on AUP and other form of attacks like phishing. Maintain a central, automated log of training completion using a Learning Management System Report awareness metrics (e.g., simulation success rates, completion percentages) to senior management in regular reviews to show continuous improvement.	HR / Security	Applicable	Training logs
	A.6.4	Disciplinary process	Formally define what constitutes an information security violation in the employee handbook Collaborate with HR to ensure these policies align with local employment legislation. Establish a Graded Disciplinary Structure Create a consistent investigation process for all security incidents to determine if violations were accidental or intentional. Provide all employees with written documentation of the disciplinary procedures and consequences.	HR	Applicable	Disciplinary policy
	A.6.5	Responsibilities after termination or change of employment	Implement a strictly enforced procedure for IT and HR to disable all user accounts Use a standardized checklist to retrieve, wipe, and document the return of all hardware (laptops, phones) and software/access tokens. Update employment contracts and NDAs to formally define which security obligations (confidentiality, IP protection) remain in force after leaving the company. Conduct a formal interview to remind departing personnel of their ongoing obligations.	HR / IT	Applicable	Access removal logs

	A.6.6	Confidentiality or non-disclosure agreements	Conduct a data discovery exercise to identify information requiring confidentiality and map data to the owner. Draft and Tailor Legally Enforceable Agreements Integrate NDA signing into the HR onboarding process for employees and the procurement process for suppliers/contractors. Maintain a Digital NDA Registry and Regular Reviews	Legal	Applicable	Signed NDAs
	A.6.7	Remote working	Include a "Clear Desk/Clear Screen" policy for home offices to prevent unauthorized access by family or visitors. Mandate the use of an encrypted Virtual Private Network (VPN) Deploy Mobile Device Management (MDM) software (e.g., Jamf, Intune) to manage and monitor all remote devices Conduct mandatory, regular, and targeted security awareness training focusing on remote-specific threats	IT	Applicable	Remote work policy
	A.6.8	Information security event reporting	Define clear reporting channels (email, phone number) in the remote work policy. Conduct mandatory awareness training on how to report events like lost devices or suspicious emails. Create a simple digital incident reporting form for remote access and logging.	Security Lead	Applicable	Event reporting records
	A.7.1	Physical security perimeters	Define boundaries (fences, walls, secured doors) to separate public/shared areas from secure areas. Deploy CCTV, alarms, and surveillance, particularly for high-sensitivity zones. Install fire detection, water leakage sensors, and UPS/generators. Position critical infrastructure (servers) away from public views or risky environmental areas (e.g., basements).	Facilities	Applicable	Physical access controls
	A.7.2	Physical entry	Use biometric scanners, keycards, or receptionists to manage access to secure areas. Physical restriction of entry, ensuring only authorized personnel have access to specific zones. Maintain a visitor logbook (electronic or physical) that records the name, company, date, time of entry/exit, and the authorized employee they are visiting. Install CCTV or motion-activated cameras at entry points. Review access logs periodically	Facilities	Applicable	Visitor logs
	A.7.3	Securing offices, rooms and facilities	Lock sensitive rooms Secure storage Control keys Monitor access Inspect regularly	Facilities	Applicable	Facility security checks
	A.7.4	Physical security monitoring	Conduct a walk-through to identify potential "blind spots." Install appropriate, tamper-proof hardware to detect breaches, such as CCTV, motion detectors, and alarm systems. Define a 24/7 "Intruder Response Process" that specifies who is called, how to verify the incident, and who is authorized to take action. Perform monthly or quarterly tests of alarm systems, motion sensors, and camera connectivity.	Facilities	Applicable	CCTV / monitoring logs
	A.7.5	Protecting against physical and environmental threats	Identify threats specific to your location, such as proximity to high-risk facilities, flood zones, or seismic activity. Install automated fire detection/suppression systems, water leak sensors, and HVAC (heating, ventilation, air conditioning) monitoring to prevent hardware degradation. Regularly test fire alarms, security systems, and emergency procedures.	Facilities	Applicable	Environmental controls
	A.7.6	Working in secure areas	Develop, approve, and communicate a Physical and Environmental Security Policy that defines secure areas Install lockers outside the perimeter for staff to store personal phones, laptops, and cameras. Ensure security personnel is always present at every time in all areas of the bank.	Facilities	Applicable	Secure area rules

Physical

A.7.7	Clear desk and clear screen	Create a formal policy mandating that confidential information must be secured in drawers at the end of the day and that screens must be locked when left unattended. Implement automatic screen locking (e.g., set to lock after 5 minutes of inactivity) and enforce mandatory password-protected screensave Provide employees with locked filing cabinets, desks, and drawers for storing sensitive physical documents Conduct regular, documented checks of workstations for compliance, especially after hours, and remove any papers from printers promptly.	All Staff	Applicable	Clean desk acknowledgements
A.7.8	Equipment siting and protection	Ensure equipment is not placed under, above, or adjacent to water pipes, potential fire hazards, or high-traffic public areas. Place servers and networking equipment in locked rooms or secured, tampering-evident cabinets. Install environmental sensors to continuously monitor for temperature, humidity, and water leaks to prevent hardware failure and install CCTV around server areas. Position monitors away from windows, reception areas, and high-traffic corridors to prevent "shoulder surfing" Secure and hide power/communications cabling in conduits to prevent accidental damage or tampering.	IT	Applicable	Equipment layout
A.7.9	Security of assets off-premises	Ensure all mobile devices, laptops, and portable storage media (USB drives) are encrypted to prevent data access if lost or stolen. Create a formal policy detailing rules for removing assets from the office, including mandatory use of VPNs for network access. Train employees on the specific risks associated with working off-premises, such as public Wi-Fi dangers and physical security threats.	IT	Applicable	Asset tracking records
A.7.10	Storage media	Create a formal policy governing the entire lifecycle of storage media, including acquisition, authorization, usage, transport, and disposal. Use cryptographic methods to protect sensitive information stored on portable media and, where appropriate, in virtual environments Keep sensitive backup tapes and external hard drives in locked cabinets, safes, or secure storage areas with access controls Securely destroy storage media after shelf life, and keep accurate records.	IT	Applicable	Media handling logs
A.7.11	Supporting utilities	List all utilities essential to your information systems and map each utility to the information system that depends on it. Determine the impact of a utility failure Maintain a risk register capturing the likelihood, impact, and existing controls.	Facilities	Applicable	Utility resilience records
A.7.12	Cabling security	Map all critical data and power cables, specifically identifying termination points, patch panels, and entry points into the facility. Perform regular physical checks for unauthorized devices ("taps") or signs of damage.	Facilities	Applicable	Cabling diagrams
A.7.13	Equipment maintenance	Establish a Comprehensive Asset Inventory and Maintenance Schedule Formally Authorize and Supervise Maintenance Personnel Maintain Detailed Maintenance Records (Evidence Logging) Apply strict security controls when maintenance occurs remotely or when equipment is removed from the premises.	IT	Applicable	Maintenance records

			Create a documented procedure that defines how to identify equipment containing sensitive information, the required data sanitization methods and the authorization process for reuse. Utilize recognized technology to destroy data before disposal or re-use. Keep detailed, auditable logs for all disposed or reused assets, including the device serial number, destruction method, date, and responsible personnel. Ensure any external vendor used for disposal is reputable, compliant with security standards, and provides certificates of destruction for all equipment.	IT	Applicable	Disposal certificates
	A.7.14	Secure disposal or re-use of equipment				
	A.8.1	User endpoint devices	Ensure all endpoint have an installed EDR agent. Enforce AES-256 encryption (e.g., BitLocker for Windows, FileVault for macOS) on all laptop Enforce Multi-Factor Authentication (MFA) for all applications and network access. Conduct regular, mandatory user training on identifying threats (e.g., phishing) and proper handling of corporate data in public areas.	IT	Applicable	MDM / endpoint reports
	A.8.2	Privileged access rights	Conduct a comprehensive audit to identify all privileged accounts across all systems, applications, and cloud environments. Implement "two-account" policy—administrators must use a standard, non-privileged account for daily tasks (email, browsing) and a separate, restricted account for administrative tasks. Implement a documented, mandatory approval process for granting privileged access. Enable detailed logging of all commands and actions performed in privileged sessions. Use a SIEM system to monitor these logs for anomalies.	IT	Applicable	PAM logs
	A.8.3	Information access restriction	Define and Document an Access Control Policy Implement Role-Based Access Control (RBAC) Automate User Lifecycle Management (Onboarding/Offboarding) Periodically review access rights, at least annually or upon major role changes, to detect "privilege creep" and also check for inactive users.	IT	Applicable	Access matrix
	A.8.4	Access to source code	Create a formal "Source Code Access Policy" that defines who can access code, under what conditions, and who has authorized "write" access, while implementing least privilege. Use version control systems (e.g., GitHub, GitLab) to enforce granular permissions rather than shared, generic accounts. Enable MFA for anyone accessing the source code. Use Static Application Security Testing (SAST) tools to automatically scan code for vulnerabilities during the commit process.	Engineering	Applicable	Repo permissions
	A.8.5	Secure authentication	Implement MFA for all remote access, administrative accounts, and access to systems holding sensitive or confidential information. Utilize phishing-resistant MFA methods (e.g., FIDO2 keys) where possible, or app-based authenticator codes. Use password managers and enforce automatic, secure password hashing Enforce automatic session termination for idle sessions and limit login attempts on apps. Log all authentication attempts both successful and failed, and review them regularly.	IT	Applicable	Authentication settings
	A.8.6	Capacity management	Define Capacity Requirements and Thresholds Create an inventory of critical IT and physical infrastructure Set up systems to continuously monitor resource usage against the defined thresholds. Create a documented "Capacity Plan" that forecasts future requirements based on business growth.	IT	Applicable	Capacity dashboards

	A.8.7	Protection against malware	Deploy Advanced Threat Protection (ATP) for email to sandbox attachments and scan links before they reach the user. Prevent the initial execution of malware by limiting the ability of users to install software, which is a primary entry point for "Shadow IT". Create a "Protection Against Malware Policy" that defines user responsibilities, prohibited activities, and incident reporting procedures and ensure staffs are trained by running phishing simulations or other forms of training.	IT	Applicable	EDR reports
	A.8.8	Management of technical vulnerabilities	Develop a detailed, up-to-date inventory of all hardware, software, applications, and cloud services. This ensures we know what needs protection. Schedule automated, authenticated, and unauthenticated scans at least monthly, or more frequently for high-risk systems Prioritize vulnerabilities based on risk rather than simply fixing everything at once. Implement compensating controls such as network segmentation, strict firewall rules (IPS/IDS), or disabling vulnerable services for system that can't be patched immediately. Run penetration test.	IT	Applicable	Vulnerability scan reports
	A.8.9	Configuration management	Define, document, and approve baseline configurations for all assets. Utilize standard benchmark like CIS Benchmarks or NIST guidelines. Deploy tools to automate the deployment, management, and monitoring of system configurations. All changes to configurations must be logged, reviewed, and authorized by designated personnel before implementation.	IT	Applicable	Configuration baselines
	A.8.10	Information deletion	Create a formal policy that defines how long different types of data (HR, customer, financial) are retained, based on legal, regulatory, and business needs. Implement automated, secure wiping software that overwrites data on storage media (hard drives, flash drives). Configure system settings to automatically purge temporary files, cached data, and old versions of documents. Maintain a log of all deletions, including who authorized it, who performed it, and when.	IT	Applicable	Secure deletion logs
	A.8.11	Data masking	Develop a Data Masking Policy and Define Scope Conduct a Data Protection Impact Assessment (DPIA) or review the Records of Processing Activities (RoPA) to identify where sensitive data flows. Enforce a policy that prohibits the use of live, raw, personal data in development, testing, or analytics environments. Implement real-time masking for production systems where authorized users may need to see some data but not all. Establish continuous monitoring and audit trails to verify that data masking is working and that unauthorized access is prevented.	Engineering	Applicable	Masking configurations
	A.8.12	Data leakage prevention	Conduct a data inventory to map where sensitive data (PII, IP, financial, confidential) is stored and moves. Deploy Endpoint and Network DLP solutions to monitor data in use, in transit, and at rest. Create a formal Data Leakage Prevention Policy outlining acceptable use, e.g ensure all data in transit or in storage use strong encryption. Conduct regular security awareness training, focusing on how to handle, share, and destroy data.	IT	Applicable	DLP policies

Technological

A.8.13	Information backup	Perform a Business Impact Analysis (BIA) to identify critical information assets, software, and systems, and define RPO and RTO. Create a policy specifying daily, weekly, and monthly backup frequencies, as well as retention periods while stating roles and responsibilities of everyone managing the data. Perform regular (e.g., quarterly or annually) restoration tests to verify data integrity and compliance with RTO/RPO requirements.	IT	Applicable	Backup reports
A.8.14	Redundancy of information processing facilities	Identify critical systems and define required availability levels, determining which assets require high availability (hot/warm standby) versus lower-cost alternatives. Deploy dual components to eliminate single points of failure, such as dual power supplies, RAID storage, redundant NICs, and secondary Internet Service Providers (ISPs) utilizing different physical paths. For cloud services, utilize multiple availability zones or regions. Set up automated alerts for component failures.	IT	Applicable	High availability architecture
A.8.15	Logging	Create a documented policy that defines what constitutes a "security event" and sets requirements for logging, monitoring, and retention Logs scattered across different systems are impossible to monitor effectively. Centralize logs to enable correlation, pattern recognition, and security analysis. Establish baselines for "normal" user activity and network traffic to identify deviations in order to detect anomalies. Implement technical controls to prevent the deletion or alteration of log files, and integrate logs into the incident response plan.	IT	Applicable	Centralized logs
A.8.16	Monitoring activities	Identify and document what needs to be monitored based on risk assessment Deploy tools to generate, collect, and store logs (e.g., SIEM, intrusion detection systems, file integrity monitoring). Move beyond simple log reviews to analyze user and system behavior to detect deviations from the norm. Regularly review monitored data and test the effectiveness of the monitoring controls through internal audits.	Security Lead	Applicable	Monitoring alerts
A.8.17	Clock synchronization	Establish a policy designating a trusted, authoritative time source for your organization, such as a reputable Stratum 1 or 2 Network Time Protocol (NTP) server Configure all servers, network devices, workstations, and relevant software to sync automatically with the authorized source using the Network Time Protocol (NTP) or Precision Time Protocol (PTP). Implement automated monitoring to detect when system clocks deviate (drift) from the approved time source beyond a set threshold. Periodically verify that all systems are still synchronizing correctly and that the time sources are still valid.	IT	Applicable	NTP configuration
A.8.18	Use of privileged utility programs	Create a register of all privileged utility programs (e.g., system admin tools, network sniffers, forensic tools) that can override system controls. Implement the principle of least privilege, granting access to these tools only to authorized staff for specific, justified, and time-limited tasks. Implement segregation of duties in the utilization of this program. Log all instances of use, including timestamps and the authorized user, and regularly review these logs to ensure compliance.	IT	Applicable	Privileged utility logs

A.8.19	Installation of software on operational systems	Remove local administrator rights from all standard user accounts on company laptops, workstations, and servers. Use centralized management tools (e.g., Intune, Jamf, Active Directory Group Policy) to restrict installation rights to IT staff only. Create and maintain a whitelist of software authorized for use, including version numbers and permissible usage scenarios.	IT	Applicable	Software allowlists
A.8.20	Networks security	Create distinct zones for sensitive data (e.g., database servers), public-facing services (DMZ), and general employee workstations. Define and enforce policies for who and what can connect to the network, adhering to the principle of least privilege. Use secure protocols (e.g., SSH, HTTPS, VPNs) for all remote access and administrative traffic. Implement a SIEM (Security Information and Event Management) system to centralize and analyze logs from firewalls, routers, and switches.	IT	Applicable	Firewall rules
A.8.21	Security of network services	Create a Network Security Policy that mandates the use of encryption for data in transit, defines user access rights based on the principle of least privilege, and dictates secure configurations for all network devices. Segment the network into distinct zones using firewalls to limit traffic flow and restrict lateral movement. Utilize encryption protocols for all sensitive data moving over internal and external networks. Implement continuous monitoring of network usage to detect unauthorized access or security incidents.	IT	Applicable	Network service configs
A.8.22	Segregation of networks	Catalog all network assets, data types, and services. Classify them based on sensitivity, functionality, and risk. Use logical separation (VLANs) to split a single physical network into multiple, isolated broadcast domains. Implement stateful firewalls or routers at the perimeter of each network segment to inspect all incoming and outgoing traffic. Use separate Service Set Identifiers (SSIDs) for employees and guests, mapping them to different VLANs.	IT	Applicable	Network segmentation diagrams
A.8.23	Web filtering	Identify which user groups and assets need restricted access. Formalize a Web Filtering and Acceptable Use Policy Deploy a Secure Web Gateway (SWG) or DNS Filter Integrate web filtering logs with a SIEM (Security Information and Event Management) system to monitor for blocked access attempts. Ensure the filtering solution automatically synchronizes with threat intelligence feeds to block new, malicious domains in real-time.	IT	Applicable	Web filtering rules
A.8.24	Use of cryptography	Define which data classifications require encryption (e.g., all PII and confidential data) and the approved algorithms/key strengths to be used The security of cryptography depends entirely on key management. ISO 27001 requires a process for the entire key lifecycle. Implement Full Disk Encryption (FDE) on all laptops, mobile devices, and servers. Perform annual (or post-incident) reviews of cryptographic standards to ensure algorithms remain secure against modern threats	IT / Security	Applicable	Encryption configurations
A.8.25	Secure development life cycle	Incorporate automated security testing directly into your continuous integration/continuous deployment (CI/CD) pipelines to detect vulnerabilities in real-time. Proactively identify potential security threats during the design phase to build "security by design and default" into your software architecture. Ensure that development, testing, and production environments are strictly separated to prevent unauthorized access and protect against accidental corruption of production data.	Engineering	Applicable	Secure SDLC documentation

	A.8.26	Application security requirements	Establish a Secure Software Development Life Cycle (SDLC) policy that covers requirements, design, testing, and implementation. Embed security testing throughout the application development lifecycle, rather than just at the end. Adopt industry frameworks like OWASP Top 10 to define security requirements. Protect data integrity and confidentiality by validating all inputs and protecting data at rest and in transit. Ensure sensitive data is encrypted using strong, modern algorithms	Procurement	Applicable	App security requirements
	A.8.27	Secure system architecture and engineering principles	Create a formal, documented policy outlining security principles that must be applied to all new systems or major upgrades. Remove unnecessary services, close unused ports, and apply security configuration benchmarks to all systems. Formally review system architecture for security vulnerabilities prior to deployment. Document and get sign-off on any deviations from the secure architecture policy, treating them as risks to be managed. Automate the auditing of configurations to ensure they adhere to secure baselines.	Engineering	Applicable	Architecture reviews
	A.8.28	Secure coding	Adopt industry-recognized frameworks such as the OWASP Top 10 or SANS Top 25 to create a mandatory security baseline and tailor to specific programming languages. Use tools to automatically scan source code for common vulnerabilities (e.g., SQL injection, XSS) every time a developer commits code. Maintain an inventory of third-party libraries and alert you to known vulnerabilities (CVEs) in those dependencies. Ensure development, testing, and production environments are strictly isolated. Never use real production data for testing purposes. Provide specialized training that goes beyond general security awareness, focusing on the specific threats relevant to your application's architecture	Engineering	Applicable	Secure code reviews
	A.8.29	Security testing in development and acceptance	Define a documented policy that mandates security testing for all new software, major updates, and significant configuration changes. Integrate security checks into the CI/CD pipeline to catch vulnerabilities early in the development process. Conduct dynamic security testing in a dedicated, isolated environment that mirrors production before final Go-Live. Require a formal, documented security sign-off from a qualified individual (e.g., Security Lead, DPO) before deploying to production.	Engineering	Applicable	Security test results
	A.8.30	Outsourced development	Create a formal, documented policy that defines how you manage information security with external developers. Contractually require developers to adhere to a Secure Development Life Cycle (SDLC). Do not give external developers unrestricted access to live production data or environments. ISO 27001 requires you to "trust but verify". You must regularly monitor and verify that the outsourced development work meets your security requirements.	Procurement	Applicable	Vendor security agreements
	A.8.31	Separation of development, test and production environments	Ensure production systems do not share infrastructure, network subnets, or database instances with development or testing teams. Never use real, live production data in testing or development environments. Establish a formal, documented process for moving software or code changes from development to test, and finally to production. Implement robust monitoring and logging of all activities, particularly the movement of data and code across environments.	IT	Applicable	Environment separation configs

	A.8.32	Change management	Establish a documented policy defining what constitutes a "change" (e.g., software updates, network changes, or organizational shifts) and a procedure for handling them. Before any change goes live, you must evaluate its potential security impact on the confidentiality, integrity, or availability of information. Ensure that all changes are authorized by appropriate personnel before implementation. Verify that changes work as intended in a staging environment and review the outcome to ensure no security issues were introduced.	IT	Applicable	Change records
	A.8.33	Test information	Do not use raw, live production data for testing. Development, testing, and production environments must be distinct and managed differently. Create a document requiring formal, documented approval from management before any production data is moved to a testing environment. Protect test data from unauthorized access, particularly in lower-security testing environments.	Engineering	Applicable	Test data controls
	A.8.34	Protection of information systems during audit testing	Documented approval between management and auditors on the exact scope, methods, and timing (e.g., off-hours) of tests. Mandate read-only access for auditors and use isolated copies of data or test environments to prevent production disruption. Verify that any devices/tools brought by auditors meet internal security requirements before allowing access. Log all auditor activity in real-time, and promptly revoke access and remove data copies upon completion of the audit.	IT / Security	Applicable	Audit testing procedures